

Conceitos de segurança e AAA

18 min de leitura · vídeo-aula 3 min · nível básico

Nesta aula vai aprender a

- ✓ Definir ameaça, vulnerabilidade, exploit e mitigação
- ✓ Reconhecer ataques comuns
- ✓ Explicar AAA, RADIUS, TACACS+ e 802.1X

Como estudar esta aula

1

Veja a vídeo-aula na app (3 min).

2

Leia este PDF com calma e sublinhe o que é importante.

3

Faça os exercícios da pág. 7.

4

Confira as soluções na pág. 10.

ANTES DESTA AULA

Esta aula continua a última aula do módulo anterior (SRWE 9): **SRWE 9 · Aula 1 de 1 — Redundância de gateway (FHRP: HSRP)**. Se ainda não a fez, comece por lá; se já a fez, releia os objetivos dela e confirme que os domina.

Índice

1. Ameaças comuns	2
2. Defesas	2
3. AAA com servidor e fallback local	3
4. Termos técnicos	3
5. Protocolos	5
6. Exercícios para fazer	7
7. Quiz	8
8. Soluções	10
9. Referências bibliográficas	11

Termo	Significado
Vulnerabilidade	Fraqueza que pode ser explorada
Ameaça	Perigo potencial que pode explorar a vulnerabilidade
Exploit	Forma/ferramenta que aproveita a vulnerabilidade
Mitigação	Medida que reduz o risco

1. Ameaças comuns

Ataque	Descrição
Phishing / spear phishing / whaling	E-mails falsos para roubar credenciais; dirigidos a uma pessoa / a executivos
DoS / DDoS	Esgotar recursos para deixar o serviço indisponível
Spoofing	Falsificar IP, MAC ou identidade
Man-in-the-middle	Intercetar a comunicação (ex.: ARP spoofing)
Reconhecimento	Recolher informação (scans, whois)
Malware	Vírus, worms, trojans, ransomware
Engenharia social	Manipular pessoas (tailgating, pretexting)
Ataques a palavras-passe	Dicionário, força bruta

2. Defesas

- **Programa de segurança:** consciencialização dos utilizadores, formação e controlo de acesso físico.
- **Palavras-passe:** preferir frases longas, MFA (algo que sabe + algo que tem + algo que é), certificados.
- **AAA: Autenticação** (quem é), **Autorização** (o que pode fazer), **Accounting** (registo do que fez).

	RADIUS	TACACS+
Transporte	UDP 1812/1813	TCP 49
Cifra	Só a palavra-passe	Todo o payload
Separa autenticação e autorização	Não	Sim
Uso típico	Acesso à rede (802.1X, VPN, Wi-Fi)	Administração de equipamentos

3. AAA com servidor e fallback local

comandos · passo a passo

```
R1(config)# aaa new-model
```

Ativa AAA (altera o login das linhas!).

```
R1(config)# tacacs server ISE
```

```
R1(config-server-tacacs)# address ipv4 10.0.0.20
```

```
R1(config-server-tacacs)# key Chave#Partilhada
```

```
R1(config)# aaa authentication login default group tacacs+ local
```

Tenta TACACS+; se não responder, usa utilizadores locais.

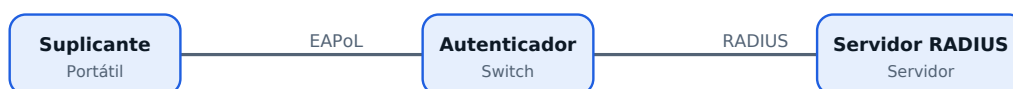


Figura: 802.1X: o switch só abre a porta depois de o servidor autenticar o utilizador.

4. Termos técnicos

O que quer dizer cada palavra técnica que aparece na aula, em linguagem simples.

AAA (Authentication, Authorization, Accounting) — Modelo de controlo de acesso: autenticação (quem é), autorização (o que pode fazer) e contabilização (o que fez). Exemplo: O administrador entra no router com a conta do servidor central e tudo o que faz fica registado.

Ameaça — Qualquer coisa ou pessoa que pode causar dano a um sistema ou aos seus dados. Exemplo: Um vírus, um hacker ou uma inundação na sala de servidores são ameaças.

Vulnerabilidade — Fraqueza num sistema que pode ser aproveitada para o atacar. Exemplo: Um router com a palavra-passe de fábrica «admin» tem uma vulnerabilidade.

Exploit — Programa ou técnica que aproveita uma vulnerabilidade concreta. Exemplo: Um exploit para uma versão antiga do Windows permite entrar sem palavra-passe.

Mitigação — Medidas para reduzir um risco. Exemplo: Atualizar o software e ativar a firewall são mitigações.

RADIUS (Remote Authentication Dial-In User Service) — Protocolo normalizado para autenticar utilizadores num servidor central; muito usado em Wi-Fi e VPN. Exemplo: O access point pergunta ao servidor RADIUS se o utilizador pode entrar (UDP 1812).

TACACS+ (Terminal Access Controller Access-Control System Plus) — Protocolo da Cisco para AAA, usado sobretudo para controlar quem administra os equipamentos de rede. Cifra a mensagem toda. Exemplo: Cada comando que o técnico escreve no router é autorizado pelo TACACS+ (TCP 49).

802.1X (IEEE 802.1X (controlo de acesso à rede por porta)) — Norma que obriga cada equipamento a autenticar-se antes de usar uma porta de switch ou o Wi-Fi. Exemplo: Ao ligar o cabo, o PC tem de dar utilizador e palavra-passe, verificados por RADIUS.

Risco — A probabilidade de uma ameaça aproveitar uma vulnerabilidade, multiplicada pelo dano que causaria. Exemplo: Servidores sem backup num local com cortes de luz têm risco alto.

Phishing — Ataque com mensagens falsas que imitam entidades de confiança para roubar dados ou palavras-passe. Exemplo: Um e-mail «do banco» a pedir para confirmar o PIN num link falso.

DoS (Denial of Service (negação de serviço)) — Ataque que tenta deixar um serviço indisponível, inundando-o de pedidos. Exemplo: Milhares de pedidos por segundo fazem o site deixar de responder.

DDoS (Distributed Denial of Service (negação de serviço distribuída)) — Ataque DoS feito ao mesmo tempo a partir de muitos equipamentos espalhados (botnet). Exemplo: 100 000 câmaras IP infetadas atacam o mesmo servidor.

Spoofing (falsificação) — Falsificar um endereço (IP, MAC) ou identidade para se fazer passar por outro. Exemplo: ARP spoofing: o atacante diz que o MAC dele é o do gateway.

IP (Internet Protocol (protocolo da Internet)) — O protocolo da camada de rede que dá endereços aos equipamentos e leva os pacotes de rede em rede até ao destino. Exemplo: Cada pacote IP tem um endereço de origem e um de destino.

Endereço MAC (Media Access Control address) — Endereço físico de 48 bits gravado na placa de rede, escrito em hexadecimal. Serve para entregar tramas dentro da rede local. Exemplo: 00:1A:2B:3C:4D:5E é um endereço MAC.

Man-in-the-middle (MITM (homem no meio)) — Ataque em que alguém se mete no meio da comunicação entre duas partes para ler ou alterar os dados. Exemplo: Um Wi-Fi falso num aeroporto que regista tudo o que passa.

ARP (Address Resolution Protocol (protocolo de resolução de endereços)) — Protocolo que descobre o endereço MAC de um equipamento a partir do seu endereço IPv4, na mesma rede local. Exemplo: O PC pergunta em broadcast «Quem tem 192.168.1.1?» e o router responde com o seu MAC.

Reconhecimento (reconnaissance) — Fase inicial de um ataque em que se recolhe informação sobre o alvo. Exemplo: Usar nmap para descobrir que portas estão abertas no servidor.

Informação — Dados organizados de forma a terem significado para quem os lê. Exemplo: «O servidor tem o IP 192.168.1.10» é informação útil para um técnico.

Malware (malicious software (software malicioso)) — Qualquer programa malicioso feito para causar dano ou roubar. Exemplo: Vírus, worms, trojans e ransomware são malware.

Vírus — Malware que se agarra a ficheiros ou programas e se espalha quando eles são abertos. Exemplo: Um vírus numa pen USB infeta o PC ao abrir um ficheiro.

Worm — Malware que se espalha sozinho pela rede, sem precisar que alguém abra um ficheiro. Exemplo: Um worm infeta todos os PCs de uma rede que não têm a atualização de segurança.

Trojan (cavalo de Troia) — Malware disfarçado de programa útil, que abre uma porta ao atacante. Exemplo: Um «jogo grátis» que instala acesso remoto escondido é um trojan.

Ransomware — Malware que cifra os ficheiros da vítima e pede resgate para os devolver. Exemplo: Um hospital sem backups fica sem acesso às fichas dos doentes até pagar.

Engenharia social — Enganar pessoas para que revelem informação ou deem acesso, em vez de atacar a tecnologia. Exemplo: Alguém telefona a fingir ser do suporte e pede a palavra-passe.

Palavra-passe — Segredo que prova que o utilizador é quem diz ser. Exemplo: Uma boa palavra-passe tem pelo menos 12 caracteres, como «Cafe-Luanda-2025!».

Força bruta (brute force) — Ataque que tenta todas as palavras-passe possíveis até acertar. Exemplo: Tentar 0000, 0001, 0002... até descobrir o PIN.

Aplicação — Programa feito para uma tarefa concreta do utilizador, que corre por cima do sistema operativo. Exemplo: O WhatsApp e o Excel são aplicações.

Utilizador — Pessoa que usa um computador ou serviço. Normalmente tem um nome de utilizador e uma palavra-passe. Exemplo: A enfermeira entra no sistema com o utilizador «ana.silva».

Autenticação multifator (MFA — Multi-Factor Authentication) — Provar a identidade com mais de um tipo de prova: algo que sabe, que tem ou que é. Exemplo: Palavra-passe + código SMS no telemóvel.

Certificado digital — Documento eletrónico que associa uma chave pública a uma identidade, assinado por uma entidade de confiança. Exemplo: O certificado do site do banco é emitido por uma autoridade de certificação.

UDP (User Datagram Protocol (protocolo de datagramas do utilizador)) — Protocolo de transporte simples e rápido: envia sem abrir ligação e sem confirmar a chegada. Exemplo: Chamadas de voz, DNS e jogos online usam UDP.

TCP (Transmission Control Protocol (protocolo de controlo de transmissão)) — Protocolo de transporte fiável: abre uma ligação, numera os dados, confirma o que chegou e reenvia o que se perdeu. Exemplo: Páginas web, e-mail e transferências de ficheiros usam TCP.

Cifra (encriptação) — Transformar dados legíveis em dados ilegíveis com uma chave, para só quem tem a chave os perceber. Exemplo: «OLA» cifrado pode ficar «X7#q»; sem a chave não se lê.

Camada de acesso à rede — Camada de baixo do modelo TCP/IP, que junta as camadas física e de ligação do OSI. Exemplo: Ethernet e Wi-Fi ficam na camada de acesso à rede.

Rede — Dois ou mais equipamentos ligados entre si para partilhar informação e recursos. Exemplo: Os computadores e a impressora de um escritório ligados ao mesmo switch formam uma rede.

VPN (Virtual Private Network (rede privada virtual)) — Túnel cifrado através da Internet que liga utilizadores ou escritórios à rede privada como se estivessem lá dentro. Exemplo: Um médico em casa entra por VPN e abre o sistema do hospital em segurança.

Wi-Fi (IEEE 802.11) — Nome comercial das redes locais sem fios baseadas nas normas IEEE 802.11. Exemplo: O telemóvel liga-se ao Wi-Fi do café para ter Internet.

Servidor — Computador ou programa que fornece um serviço a outros (clientes). Exemplo: Um servidor DHCP dá endereços IP aos PCs da rede.

Login local — Faz o equipamento pedir utilizador e palavra-passe da sua base local. Exemplo: `username admin secret Abc123! + line vty 0 15 → login local`.

5. Protocolos

Wi-Fi — Wi-Fi (IEEE 802.11 - rede local sem fios)

camada OSI 2 · TCP/IP: Acesso à rede

Permite ligar portáteis, telemóveis e outros dispositivos à rede por ondas de rádio, sem cabo. Usa as bandas de 2,4 GHz, 5 GHz e 6 GHz.

ARP — Address Resolution Protocol (protocolo de resolução de endereços)

camada OSI 2 · TCP/IP: Acesso à rede

Descobre o endereço MAC que corresponde a um endereço IPv4 na mesma rede local. Sem ARP o PC sabe o IP de destino mas não consegue montar a trama Ethernet. (O antigo RARP fazia o contrário e foi substituído pelo DHCP.)

TCP — Transmission Control Protocol (protocolo de controlo de transmissão)

camada OSI 4 · TCP/IP: Transporte · portas: 0-65535 (ex.: 80, 443, 22, 445)

Garante que os dados chegam completos, sem erros e pela ordem certa. É usado quando não se pode perder nada: páginas web, e-mail, ficheiros.

UDP — User Datagram Protocol (protocolo de datagramas do utilizador)

camada OSI 4 · TCP/IP: Transporte · portas: 0-65535 (ex.: 53, 67/68, 69, 123, 161)

Envia dados rapidamente, sem ligação nem confirmações. É usado quando a rapidez importa mais do que perder um pedaço: voz, vídeo, DNS, jogos.

RADIUS — Remote Authentication Dial-In User Service (serviço de autenticação remota)

camada OSI 7 · TCP/IP: Aplicação · transporte: UDP · portas: UDP 1812 (autenticação), UDP 1813 (contabilização)

Centraliza a autenticação de utilizadores que entram na rede: Wi-Fi empresarial, VPN e 802.1X.

Faz AAA: autenticação, autorização e registo (accounting).

TACACS+ — Terminal Access Controller Access-Control System Plus

camada OSI 7 · TCP/IP: Aplicação · transporte: TCP · portas: TCP 49

Protocolo AAA usado sobretudo para controlar quem entra nos routers e switches e que comandos pode executar. Regista cada comando escrito pelos administradores.

802.1X/EAP — IEEE 802.1X com Extensible Authentication Protocol (controlo de acesso por porta)

camada OSI 2 · TCP/IP: Acesso à rede · portas: — (EAPOL na LAN; RADIUS UDP 1812 até ao servidor)

Obriga cada dispositivo a autenticar-se antes de usar uma porta de switch ou o Wi-Fi. Quem não se autentica não entra na rede.

6. Exercícios para fazer

Os 10 exercícios obrigatórios desta aula. Responda à mão nas linhas; as soluções, com a resolução, estão no fim deste PDF. Na app pode fazer exercícios novos sem fim.

1. O que significa **Worm**?

- ☐ **A)** Conector pequeno de fibra ótica, com encaixe por patilha, muito usado em módulos SFP.
- ☐ **B)** Valor que um protocolo de encaminhamento usa para comparar caminhos para a mesma rede; o menor ganha.
- ☐ **C)** Malware que se espalha sozinho pela rede, sem precisar que alguém abra um ficheiro.
- ☐ **D)** Ataque que tenta todas as palavras-passe possíveis até acertar.

2. Para que serve **RADIUS**?

- ☐ **A)** Transfere e gere ficheiros remotos através de uma ligação SSH, com tudo cifrado. Não confundir com FTPS, que é FTP com TLS.
- ☐ **B)** Protocolo da Cisco que negocia automaticamente se uma ligação entre dois switches passa a trunk. É prático, mas é considerado um risco e costuma ser desligado.
- ☐ **C)** Versão aberta do HSRP: vários routers partilham um gateway virtual e um assume se o outro falhar. Funciona entre marcas diferentes.
- ☐ **D)** Centraliza a autenticação de utilizadores que entram na rede: Wi-Fi empresarial, VPN e 802.1X. Faz AAA: autenticação, autorização e registo (accounting).

3. O que quer dizer a sigla **IP**?

- ☐ **A)** Port Address Translation; também NAT overload
- ☐ **B)** Internet Protocol (protocolo da Internet)
- ☐ **C)** block size
- ☐ **D)** Bridge Protocol Data Unit

4. O que significa **DDoS** (Distributed Denial of Service (negação de serviço distribuída))?

- ☐ **A)** Protocolo que estabelece e termina chamadas de voz e vídeo sobre IP.
- ☐ **B)** Ataque DoS feito ao mesmo tempo a partir de muitos equipamentos espalhados (botnet).
- ☐ **C)** O endereço do router que o PC usa para enviar pacotes para fora da sua rede.
- ☐ **D)** Proteção do switch que só aceita respostas DHCP vindas de portas de confiança.

5. O que quer dizer a sigla **RADIUS**?

- ☐ **A)** brute force
- ☐ **B)** Carrier Sense Multiple Access with Collision Detection
- ☐ **C)** Remote Authentication Dial-In User Service
- ☐ **D)** Maximum Transmission Unit (unidade máxima de transmissão)

6. O que quer dizer a sigla **DoS**?

- ☐ **A)** EMI/RFI — interferência eletromagnética / de radiofrequência
- ☐ **B)** Denial of Service (negação de serviço)
- ☐ **C)** levantamento de cobertura
- ☐ **D)** VLANs permitidas

7. O que significa Utilizador?

- ☐ **A)** Pessoa que usa um computador ou serviço. Normalmente tem um nome de utilizador e uma palavra-passe.
- ☐ **B)** Protocolo de encaminhamento usado dentro de uma única organização.
- ☐ **C)** Protocolo de transporte simples e rápido: envia sem abrir ligação e sem confirmar a chegada.
- ☐ **D)** Protocolo que transporta o áudio e o vídeo de uma chamada em tempo real, sobre UDP.

8. Em que camada OSI trabalha UDP?

- ☐ **A)** 4 — Transporte
- ☐ **B)** 3 — Rede
- ☐ **C)** 1 — Física
- ☐ **D)** 2 — Ligação de dados

9. Que porta usa TCP?

- ☐ **A)** UDP/TCP 5060, TCP 5061 (SIP sobre TLS)
- ☐ **B)** TCP 143, TCP 993 (IMAPS com TLS)
- ☐ **C)** 0-65535 (ex.: 80, 443, 22, 445)
- ☐ **D)** TCP 830 (sobre SSH)

10. O que quer dizer a sigla AAA?

- ☐ **A)** criptografia de chave pública
- ☐ **B)** Dynamic ARP Inspection (inspeção dinâmica de ARP)
- ☐ **C)** rack
- ☐ **D)** Authentication, Authorization, Accounting

7. Quiz

4 perguntas. Para concluir a aula na app precisa de 70% no quiz.

1. Que protocolo AAA usa TCP 49 e cifra todo o pacote?

- ☐ **A)** RADIUS
- ☐ **B)** TACACS+
- ☐ **C)** Kerberos
- ☐ **D)** LDAP

2. No 802.1X, o switch tem o papel de...

- ☐ **A)** Suplicante
- ☐ **B)** Autenticador
- ☐ **C)** Servidor de autenticação
- ☐ **D)** NMS

3. Um e-mail falso dirigido especificamente ao diretor financeiro é...

- ☐ **A)** Vishing
- ☐ **B)** Whaling
- ☐ **C)** Smishing
- ☐ **D)** Spam

4. Accounting regista o que o utilizador fez.

☐ Verdadeiro ☐ Falso

Porquê? _____

8. Soluções

Exercícios

1. **Resposta:** C) Malware que se espalha sozinho pela rede, sem precisar que alguém abra um ficheiro.
Worm: Malware que se espalha sozinho pela rede, sem precisar que alguém abra um ficheiro.
Exemplo: Um worm infeta todos os PCs de uma rede que não têm a atualização de segurança.
2. **Resposta:** D) Centraliza a autenticação de utilizadores que entram na rede: Wi-Fi empresarial, VPN e 802.1X. Faz AAA: autenticação, autorização e registo (accounting).
Remote Authentication Dial-In User Service (serviço de autenticação remota). Centraliza a autenticação de utilizadores que entram na rede: Wi-Fi empresarial, VPN e 802.1X. Faz AAA: autenticação, autorização e registo (accounting).
3. **Resposta:** B) Internet Protocol (protocolo da Internet)
IP = Internet Protocol (protocolo da Internet). O protocolo da camada de rede que dá endereços aos equipamentos e leva os pacotes de rede em rede até ao destino.
4. **Resposta:** B) Ataque DoS feito ao mesmo tempo a partir de muitos equipamentos espalhados (botnet).
DDoS: Ataque DoS feito ao mesmo tempo a partir de muitos equipamentos espalhados (botnet).
Exemplo: 100 000 câmaras IP infetadas atacam o mesmo servidor.
5. **Resposta:** C) Remote Authentication Dial-In User Service
RADIUS = Remote Authentication Dial-In User Service. Protocolo normalizado para autenticar utilizadores num servidor central; muito usado em Wi-Fi e VPN.
6. **Resposta:** B) Denial of Service (negação de serviço)
DoS = Denial of Service (negação de serviço). Ataque que tenta deixar um serviço indisponível, inundando-o de pedidos.
7. **Resposta:** A) Pessoa que usa um computador ou serviço. Normalmente tem um nome de utilizador e uma palavra-passe.
Utilizador: Pessoa que usa um computador ou serviço. Normalmente tem um nome de utilizador e uma palavra-passe.
Exemplo: A enfermeira entra no sistema com o utilizador «ana.silva».
8. **Resposta:** A) 4 — Transporte
UDP → camada 4 — Transporte (TCP/IP: Transporte). Envia dados rapidamente, sem ligação nem confirmações. É usado quando a rapidez importa mais do que perder um pedaço: voz, vídeo, DNS, jogos.
9. **Resposta:** C) 0-65535 (ex.: 80, 443, 22, 445)
TCP: porta 0-65535 (ex.: 80, 443, 22, 445), transporte —.
10. **Resposta:** D) Authentication, Authorization, Accounting
AAA = Authentication, Authorization, Accounting. Modelo de controlo de acesso: autenticação (quem é), autorização (o que pode fazer) e contabilização (o que fez).

Quiz — chave de respostas

1. **Resposta:** B) TACACS+
TACACS+.
2. **Resposta:** B) Autenticador
Autenticador.
3. **Resposta:** B) Whaling
Whaling = phishing dirigido a executivos.

4. Resposta: Verdadeiro

É o terceiro A.

9. Referências bibliográficas

1. RIGNEY, C. et al. RFC 2865: Remote Authentication Dial In User Service (RADIUS). IETF, 2000.
2. DAHM, T. et al. RFC 8907: The TACACS+ Protocol. IETF, 2020.
3. IEEE. IEEE 802.1X: Port-Based Network Access Control. New York: IEEE, 2020.
4. NIST. SP 800-63B: Digital Identity Guidelines – Authentication and Lifecycle Management. Gaithersburg: NIST, 2017.
5. ODOM, Wendell. CCNA 200-301 Official Cert Guide, Volume 2. 2. ed. Hoboken: Cisco Press, 2024.